Lab 1a Report – Rule-Based Detection & MITRE ATT&CK

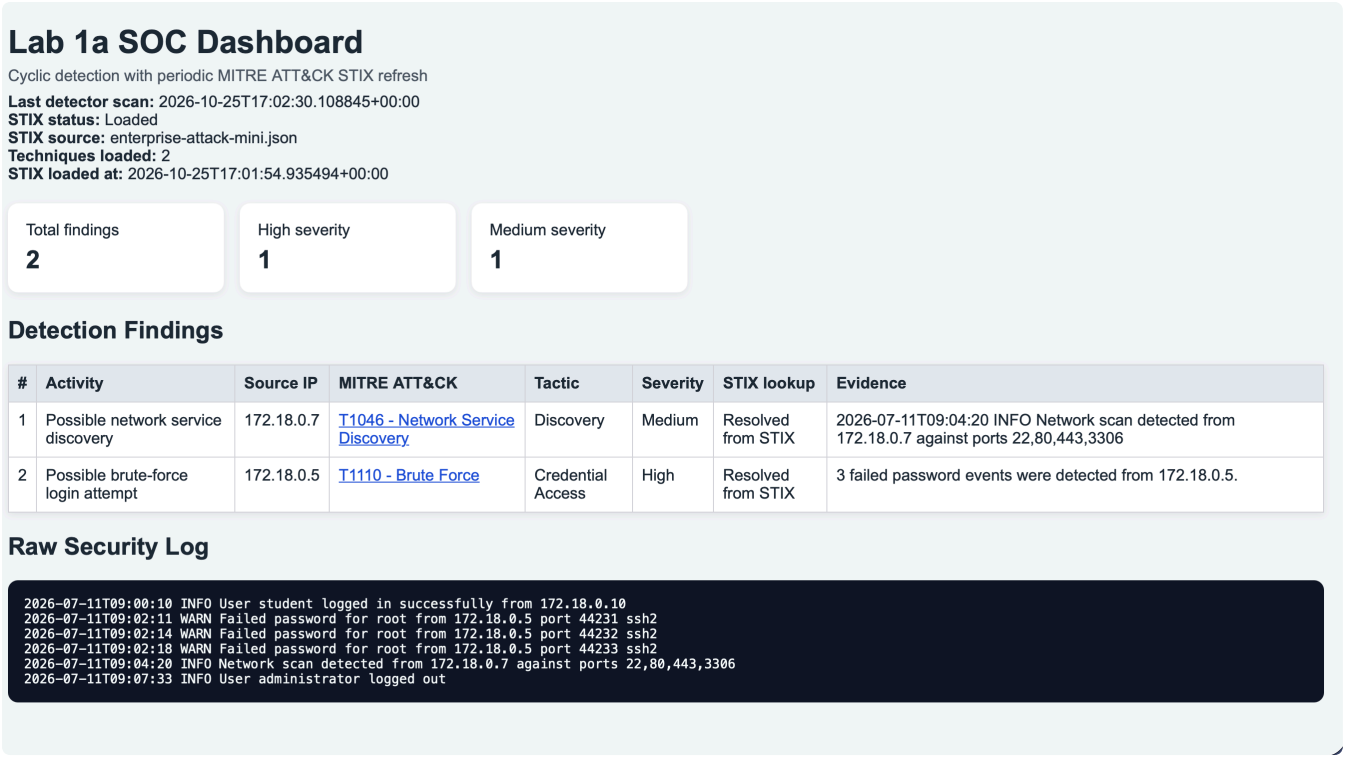
noam and ofek

HIT • AI-Driven Cybersecurity • Laboratory 1a

1. Docker verification

Docker and both lab services ran correctly on macOS (Apple Silicon). The lab was run in zsh, so the guide's PowerShell commands were replaced with their Unix equivalents (`grep -c`, `cp`, `cat`, `echo >>`).

Component	Value
Docker Desktop	4.96.3
Docker client / engine	29.9.2 / 29.9.2
Engine platform	linux/arm64
`mitre-log-detector`	Up (FAILED_PASSWORD_THRESHOLD=3, SCAN_INTERVAL_SECONDS=5)
`lab1a-dashboard`	Up, published on port 8000
STIX status on dashboard	Loaded, enterprise-attack-mini.json, 2 techniques



Lab 1a SOC Dashboard

Cyclic detection with periodic MITRE ATT&CK STIX refresh

Last detector scan: 2026-10-25T17:02:30.108845+00:00
STIX status: Loaded
STIX source: enterprise-attack-mini.json
Techniques loaded: 2
STIX loaded at: 2026-10-25T17:01:54.935494+00:00

Total findings 2 | High severity 1 | Medium severity 1

Detection Findings

#	Activity	Source IP	MITRE ATT&CK	Tactic	Severity	STIX lookup	Evidence
1	Possible network service discovery	172.18.0.7	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-07-11T09:04:20 INFO Network scan detected from 172.18.0.7 against ports 22,80,443,3306
2	Possible brute-force login attempt	172.18.0.5	T1110 - Brute Force	Credential Access	High	Resolved from STIX	3 failed password events were detected from 172.18.0.5.

Raw Security Log

```
2026-07-11T09:00:10 INFO User student logged in successfully from 172.18.0.10
2026-07-11T09:02:11 WARN Failed password for root from 172.18.0.5 port 44231 ssh2
2026-07-11T09:02:14 WARN Failed password for root from 172.18.0.5 port 44232 ssh2
2026-07-11T09:02:18 WARN Failed password for root from 172.18.0.5 port 44233 ssh2
2026-07-11T09:04:20 INFO Network scan detected from 172.18.0.7 against ports 22,80,443,3306
2026-07-11T09:07:33 INFO User administrator logged out
```

Figure 1. Dashboard at http://localhost:8000 with the clean six-line baseline.

2. Initial finding count

The clean six-line baseline produced exactly 2 findings (`finding_count: 2`), matching the validated starting state.

#	Source IP	Technique	Tactic	Severity	Evidence
1	172.18.0.7	T1046 – Network Service Discovery	Discovery	Medium	Log line 5
2	172.18.0.5	T1110 – Brute Force	Credential Access	High	Log lines 2–4

The log line count was verified with `grep -c '' logs/security.log` (result: 6) before any experiment. Both findings show STIX lookup status "Resolved from STIX".

3. Evidence → rule → technique → tactic → uncertainty

Both baseline findings are rule matches consistent with an ATT&CK technique, not confirmed attacks.

	Evidence	Rule	Technique	Tactic	Uncertainty
T1110	Lines 2–4: three `Failed password for root` events from 172.18.0.5 (ports 44231–44233), 09:02:11–09:02:18 on 2026-07-11	At least 3 lines containing "Failed password" from the same source IP (threshold 3). No time window	T1110 – Brute Force (candidate), resolved from STIX object `attack-pattern--lab1a-t1110`	Credential Access	Three failures in 7 seconds fit automated guessing, but also a user or script with a wrong password. No successful login from 172.18.0.5 appears, so there is no evidence of compromise. The IP may be shared or NATed. The threshold is arbitrary
T1046	Line 5: `Network scan detected from 172.18.0.7 against ports 22,80,443,3306` at 09:04:20 on 2026-07-11	Any line containing "network scan detected"; matching is case-insensitive (rule text is lowercase, log line starts with "Network")	T1046 – Network Service Discovery (candidate), resolved from STIX object `attack-pattern--lab1a-t1046`	Discovery	Depends entirely on an upstream sensor's message; no packet or flow data to verify it. The target host is not named. An authorized scan would produce the same line. No follow-up activity from 172.18.0.7 was observed

The two findings come from different IPs, and the scan (09:04:20) follows the login failures (09:02), so no link between them is established. The one successful login (line 1) came from a third IP, 172.18.0.10.

4. Experiments C1–C4

All four predictions matched the actual results. The simulator was stopped throughout, and each result was checked against `generated_at` in output/findings.json to confirm it came from a scan after the edit. Experiments were cumulative.

Exp.	Changed log lines	Predicted	Actual	Explanation
C1	Deleted the 172.18.0.5 failure on port 44233, leaving 2 failures from that IP	T1110 disappears, T1046 remains, total 1	`finding_count: 1`, T1046 (172.18.0.7) only	2 failures are below the threshold of 3
C2	Three failures, one each from 172.18.0.5, 172.18.0.6, 172.18.0.8	No T1110, total 1	`finding_count: 1`, T1046 only	Failures are counted per source IP; no single IP reaches 3
C3	Appended 3 failures for user `test` from 192.0.2.55 (2026-10-22, `Z` timestamps)	New T1110 for 192.0.2.55, total 2	`finding_count: 2`, T1046 (172.18.0.7) + T1110 (192.0.2.55)	3 failures from one IP reach the threshold
C4	Appended `Network scan detected from 192.0.2.77 against ports 22,80,443`	Second T1046, total 3	`finding_count: 3`, T1046 ×2 + T1110 ×1	Every line with the trigger text produces a finding, with no threshold

Observations on rule limitations:

- **C2:** distributed guessing across several IPs (e.g. password spraying) stays below the per-IP threshold and is missed.
- **C3:** the different timestamp format, date and target user (`test` instead of `root`) had no effect; the rule reads only the trigger text and the IP.
- **C4:** the finding repeats a judgment already made by another sensor; if that sensor is wrong, the detector cannot tell.

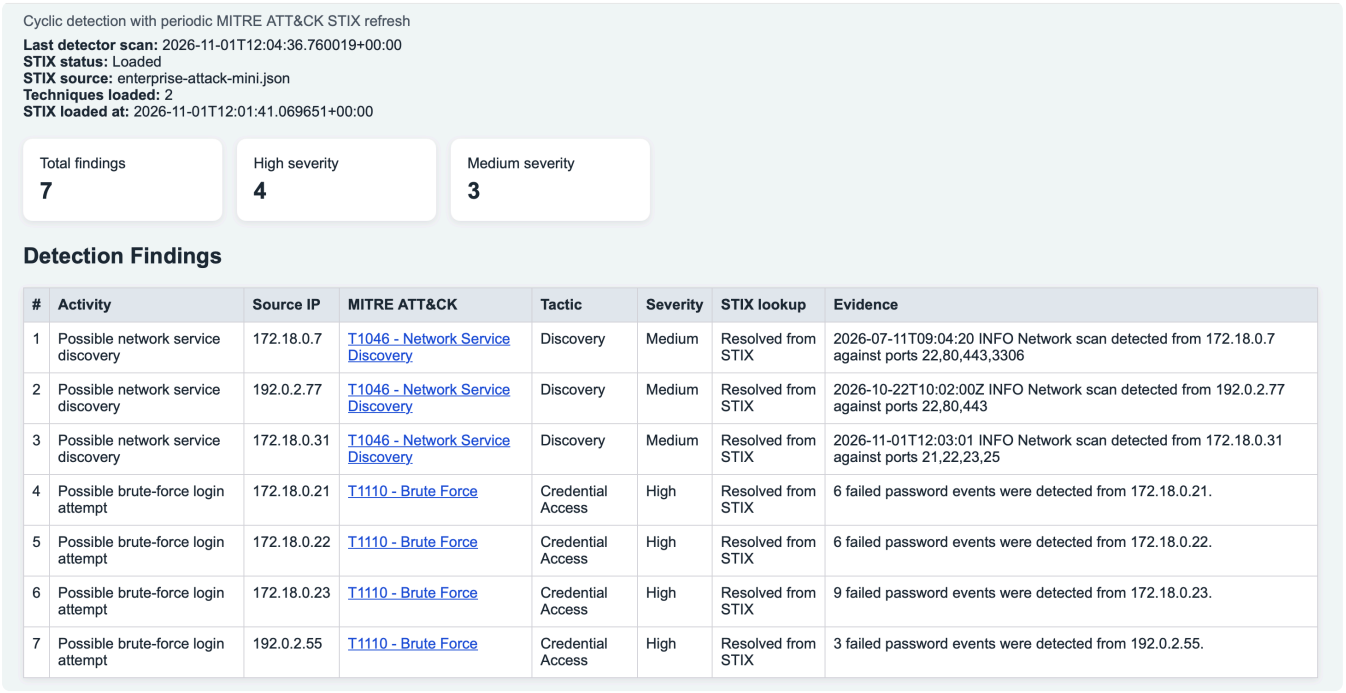
5. Simulator observation

Observation: the finding count rose in steps from 3 to 7 and then held at 6 for 40 seconds while attacks continued, because the detector creates one finding per source IP. Repeated failures from a known IP only raise its `failed_attempts` counter (172.18.0.23

reached 9), and severity stays High regardless of volume. A stable count therefore does not mean no activity.

Time (UTC)	Simulated event	New finding	Total
Before start	State after C4	—	3
12:01:41	3 failures from 172.18.0.21	T1110	4
12:01:51	3 failures from 172.18.0.23	T1110	5
12:02:01	3 more from 172.18.0.23	None	5
12:02:11	3 failures from 172.18.0.22	T1110	6
12:02:21–31	Successful logins from 172.18.0.12 and 172.18.0.11	None	6
12:02:41–51	More failures from 172.18.0.22 and 172.18.0.23	None	6
12:03:01	Network scan from 172.18.0.31	T1046	7
12:03:11	3 more from 172.18.0.21	None	7

- **Which new source IPs appear?** 172.18.0.21, .22, .23 (failed passwords), 172.18.0.31 (scan), and 172.18.0.11, .12 (successful logins, no finding).
- **Which events create T1110 findings?** Only the first burst of 3 failures from each new IP.
- **Which events create T1046 findings?** The line `Network scan detected from 172.18.0.31 against ports 21,22,23,25`.
- **Do the finding counts remain stable or change over time?** They change in steps, only when a new IP crosses the threshold or a new scan line appears.
- **Why is this simulator less reproducible than the controlled manual experiments?** IPs, event types and ports vary between runs; the result depends on when it is sampled relative to three cycles (simulator 10 s, detector 5 s, browser ~3 s); and the log is cumulative, so the starting state affects the end state.



Cyclic detection with periodic MITRE ATT&CK STIX refresh

Last detector scan: 2026-11-01T12:04:36.760019+00:00
STIX status: Loaded
STIX source: enterprise-attack-mini.json
Techniques loaded: 2
STIX loaded at: 2026-11-01T12:01:41.069651+00:00

Total findings	High severity	Medium severity
7	4	3

Detection Findings

#	Activity	Source IP	MITRE ATT&CK	Tactic	Severity	STIX lookup	Evidence
1	Possible network service discovery	172.18.0.7	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-07-11T09:04:20 INFO Network scan detected from 172.18.0.7 against ports 22,80,443,3306
2	Possible network service discovery	192.0.2.77	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-10-22T10:02:00Z INFO Network scan detected from 192.0.2.77 against ports 22,80,443
3	Possible network service discovery	172.18.0.31	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-11-01T12:03:01 INFO Network scan detected from 172.18.0.31 against ports 21,22,23,25
4	Possible brute-force login attempt	172.18.0.21	T1110 - Brute Force	Credential Access	High	Resolved from STIX	6 failed password events were detected from 172.18.0.21.
5	Possible brute-force login attempt	172.18.0.22	T1110 - Brute Force	Credential Access	High	Resolved from STIX	6 failed password events were detected from 172.18.0.22.
6	Possible brute-force login attempt	172.18.0.23	T1110 - Brute Force	Credential Access	High	Resolved from STIX	9 failed password events were detected from 172.18.0.23.
7	Possible brute-force login attempt	192.0.2.55	T1110 - Brute Force	Credential Access	High	Resolved from STIX	3 failed password events were detected from 192.0.2.55.

Figure 2. Dashboard after the simulator run: 7 findings (4 High, 3 Medium).

6. SOC narrative

To write: 100–150 words in your own words. Replace the bracketed prompts, then delete this line.

6. SOC narrative

On 2026-07-11, the security log recorded three failed root logins from 172.18.0.5 within seven seconds. This was preceded by one successful login from 172.18.0.10. Two minutes later, an upstream sensor detected a network scan hitting multiple ports from 172.18.0.7.

The failed logins are consistent with T1110 (Credential Access), while the scan matches T1046 (Discovery). However, neither proves an actual compromise. There was no successful login from 172.18.0.5, and the scan alert lacks the packet data needed to verify its intent. Furthermore, since these events originated from different IPs at different times, there is no technical reason to link them.

A major limitation of this rule-based setup, as seen in experiment C2, is that a static per-IP threshold easily misses distributed attacks like password spraying. My next step as an analyst would be inspecting the raw PCAP files and checking if the IPs are internal or NATed.